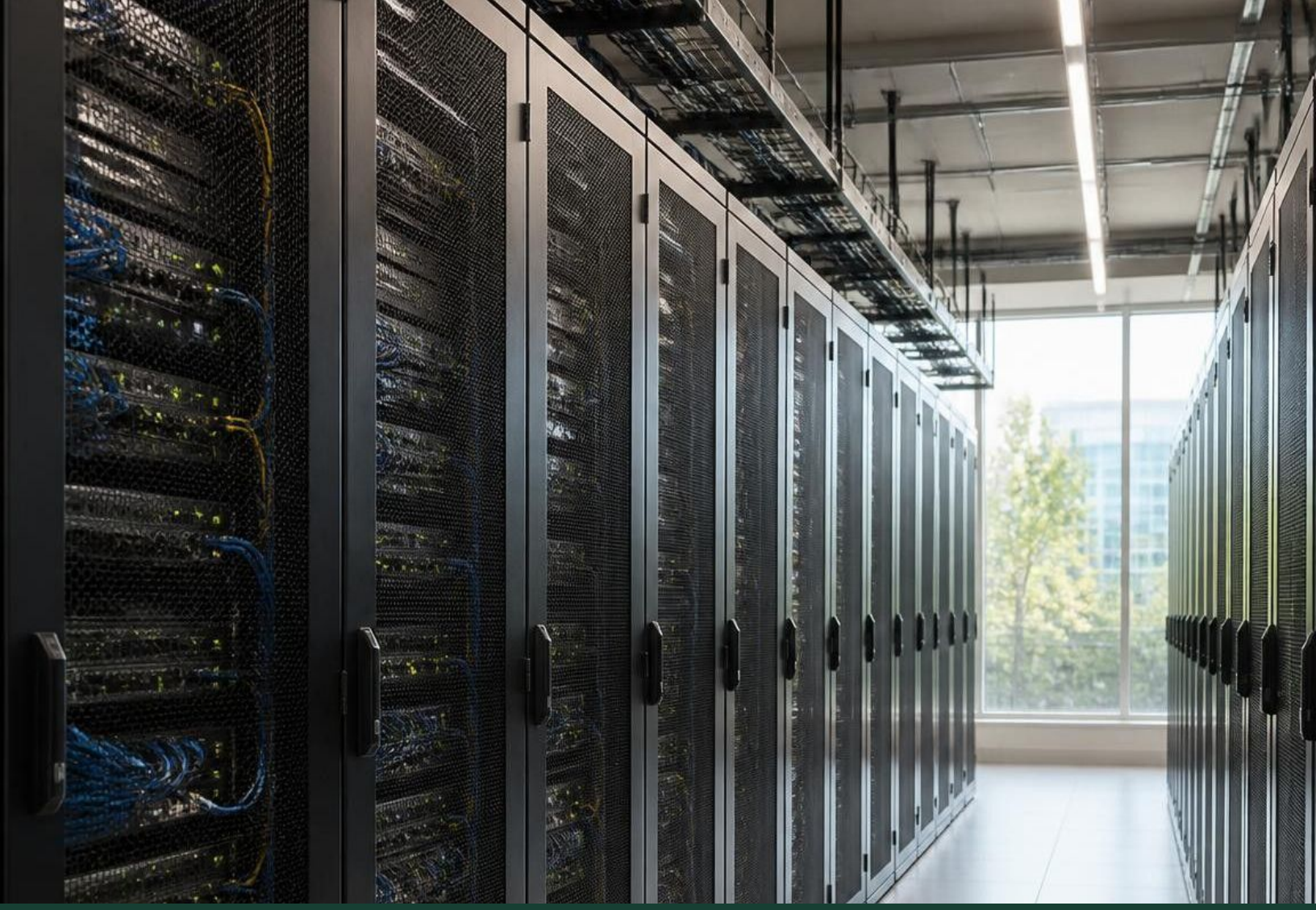


A Policy Without a Control

Governance as Architecture for Enterprise AI

A paper by Aejaz Sheriff Quaraishi, November 2026

Turn written commitments into controls that run wherever AI acts.

A policy without a control is just documentation

Governance becomes credible when its requirements run every time an AI system acts.

Most programs have principles, a policy and a committee. Fewer can show the checks that enforce those commitments in production.

84%

of 93 health insurers surveyed by NAIC in 2025 use AI or ML.

Nearly 92%

report governance principles aligned with NAIC's; nearly a third do not regularly test models for bias.

Seven ideas, one operating architecture

Govern delegated work; tier by component and consequence; choose rules, models and agents deliberately; build a control plane; reuse one evidence set; govern value claims; and make the governed path fast.

For chief data, AI and risk officers, platform architects, and leaders who stand behind what AI does. Survey context: NAIC, 2025.

Why AI governance programs stall

Policy often arrives before an inventory. It misses AI inside purchased software and the tools staff adopt themselves. Without a useful approved register, shadow use becomes the practical alternative.

The queue replaces the control

A single review board becomes a bottleneck. Teams relabel projects to avoid it rather than improve the design.

The audit replaces the evidence

Records are reconstructed by hand at audit time, then become stale once filed.



The common cause is structural: governance lives in documents and meetings rather than in the systems where AI runs. Framed as control, governance is resisted; framed as a service, it gets adopted.

Govern delegated work, not only models

AI arrived inside purchased software, assistants became general purpose, and agents started acting. A model-only inventory no longer describes the work being delegated.

The task is the unit of governance

Record what work is delegated, on whose authority, using which tools and data, with what consequence, and who checks the result. The same model can support tasks with very different risks.

Identity must tell the truth

Give agents their own non-human identities and scoped permissions. An audit trail should identify the agent that acted, not imply that a person performed its work.



Inventory custom models, vendor AI features, assistants, agents and sanctioned personal tools. Tier every delegated task.

The component × consequence matrix assigns every task a tier

Classify the component and the consequence together. The matrix is the starting assignment; the rules on the next page can raise it.

COMPONENT	INFORMATIONAL	INTERNAL OPERATIONAL	EXTERNAL REVERSIBLE	CONSEQUENTIAL TO A PERSON
Deterministic automation	Tier 1	Tier 1	Tier 2	Tier 3
Predictive model	Tier 1	Tier 2	Tier 3	Tier 4
Generative assistant	Tier 1	Tier 2	Tier 3	Tier 4
Agent	Tier 2	Tier 2	Tier 3	Tier 4

Four tiers, increasing control obligations. Color supplements the written tier labels.

Consequences dominate sophistication

Every probabilistic component is tier 4 when eligibility, coverage, credit, employment or health is at stake. Deterministic automation sits at tier 3 in that column because its logic can be read, tested and replayed.

Four rules keep the tiering honest

1

Apply the composite rule

A system takes the highest tier of any component-consequence pair it contains. A low-risk interface cannot lower the tier of the consequential task behind it.

2

Respect the agentic floor

Any agent is at least tier 2. Write access to a system of record makes it at least tier 3.

3

Tier the adverse direction

Use the worst direction the system can act, such as denial. California and Texas bar automated adverse medical necessity determinations.

4

Detect drift to the right

Monitor override and correction rates for tiers 3 and 4. When people stop changing outputs, re-tier the task or restore meaningful checks.

Controls accumulate as the tier rises

Tier 1 and 2 need little; tier 4 carries everything above plus its own column.

CONTROL	TIER 1	TIER 2	TIER 3	TIER 4
Inventory entry and named owner	Yes	Yes	Yes	Yes
Approved tool or platform only	Yes	Yes	Yes	Yes
Evaluation before release	—	Basic	Pre-registered thresholds	Pre-registered, independent validation
Logging of inputs, outputs and versions	—	Yes	Yes, through the gateway	Yes, sealed decision trace
Documented risk assessment	—	—	Yes	Yes, plus impact assessment
Human review before external effect	—	—	Yes	Accountable person decides adverse outcomes
Fairness and bias testing	—	—	Where people are affected	Required, ongoing
Deterministic gate on decisions	—	—	—	Required
Override and correction monitoring	—	—	Yes	Yes
Review cadence	On change	Annual	Semiannual	Quarterly

Use a rule when there is one right answer

1. Should this step exist at all?
2. One right answer given the inputs? Use deterministic logic.
3. Many acceptable answers judged by quality? Use a model, with output treated as a proposal.
4. Steps known in advance? Build a fixed workflow that calls models where needed.
5. Steps depend on what is found along the way? Only then consider an agent.

DETERMINISTIC SAFETY PRINCIPLE

Models propose. Deterministic rules decide. Accountable people sign.

A model never generates a final dollar amount, dose or legally effective date.

A budget-change request needs no agent

For a regulated budget-change request, a fixed workflow can collect inputs, use a model to draft the explanation, calculate amounts deterministically and route approval to a person. The worked example lands in tier 2.

The AI control plane turns written policy into runtime checks

Put shared controls between applications and the models, tools and data they use. Keep policy definitions separate from enforcement engines.

Applications and delegated tasks

Identity, owner and assigned tier travel with the request.

AI control plane

Model gateway · signed prompt and agent registry · guardrails · evaluation harness

Policy as code: routing, access, cost and residency, for example Open Policy Agent or Cedar

Observability · evidence collector · continuous fairness monitoring

Models, tools and data

Governed tool-protocol gateway and agent-to-agent authentication

Release controls apply to definitions too

Tier 3 and 4 prompts and agent definitions ship as signed, evaluated releases, not Friday-afternoon console edits. Agents receive tool allowlists, budget caps and loop breakers. Protected attributes stay in the monitoring layer.

One evidence set serves NIST AI RMF and ISO/IEC 42001

Produce artifacts once. Cite them against both frameworks.

NIST supplies the operating playbook

NIST AI RMF, published in January 2023, organizes work around Govern, Map, Measure and Manage. Its Generative AI Profile, AI 600-1, followed in July 2024.

ISO supplies the management system

ISO/IEC 42001:2023 is certifiable and auditable, aligned with ISO 27001 and 9001.

The shared record

Inventory, tier records, impact assessments, signed evaluations, gateway logs, monitoring dashboards and incident records form one maintained evidence set. Framework mappings point to those records rather than creating parallel files.

Certification is a procurement signal, not a legal safe harbor. Colorado's framework-based defense was repealed and replaced in 2026.

Baseline before benefit: govern value claims too

No value claim without a baseline measured before the AI went in.

A governed value case states the baseline, a pre-registered target and an attribution method. A KPI dictionary fixes what each measure means. Safe-behavior measures and honestly counted costs belong beside the benefit.

Targets shape behavior

A target of reduced claims spend tells systems to find reasons to pay less. Review the behavior a success definition rewards before approving it.

Independent people attest

Finance attests financial benefits. Internal audit examines the method. The team making the claim should not be its only judge.

Value affects continued permission

Tiers 1 and 2 get a stated benefit and a six-month check. A tier 4 system that cannot demonstrate value is a candidate for retirement.

Make the governed path the fastest path

Tier 1 · Same day

Self-service from the approved register.

Tier 2 · Within a week

Domain owner approval.

Tier 3 · Two to three weeks

AI governance office with risk and security.

Tier 4 · Set per case

Governance committee with the accountable executive.

Illustrative service targets, not approval guarantees.

A small governance office coordinates domain owners, risk and legal, and internal audit. The platform team acts as an enablement service; the accountable executive retains accountability.



Deliver acceptable-use policy, tool register, approval matrix, risk-tiered intake, inventory and evidence reporting. Centralize identity and inventory, not records.

Assess maturity on evidence, then follow a four-phase roadmap

Evidence first, score second: T0 absent, T1 defined, T2 operating, T3 managed. Area owners attest their rows; leadership ratifies. A credibility matrix marks external claims clear, conditional or blocked.

1 **Baseline**

Inventory, assessment and tiering. The gate is a leadership-accepted list with owners for every tier 3 and 4 system.

2 **Design**

Policy, register, intake, control-plane specification and framework mapping.

3 **Embed**

Route traffic through the gateway, signed registry, evaluation gates and monitoring.

4 **Sustain**

Review cadence, drift-right watch, incidents, audit and management review. Consider ISO/IEC 42001 certification.



The regulatory horizon through 2028 rewards building in now

2025

EU AI Act: prohibited practices, Feb 2; general-purpose AI, Aug 2.

2026

EU AI Act transparency requirements, Aug 2.

2027

Colorado SB 26-189, Jan 1: notice, explanation and consumer rights. EU high-risk standalone systems, Dec 2.

2028

EU AI embedded in products, Aug 2.

EU high-risk dates reflect the 2026 Digital Omnibus schedule stated in this paper.

The overlapping control requirements

Inventory, risk classification, documentation, testing, human oversight, explanation and records recur across the landscape. US state and sector measures include the NAIC model bulletin in nearly 30 states, California SB 1120, Texas SB 815 and banking model risk guidance SR 11-7.

Summary as of November 2026, not legal advice. Confirm applicable requirements and effective dates before relying on this schedule.